Unsalted MD5 Password Storage

SHOP-007 — Vulnerability Assessment Finding Report

Field	Value
Finding ID	SHOP-007
Product	PHPGurukul Online Shopping Portal
Version	V2.0 package (product page labelled V2.1); SQL dump dated 2025-01-02
Developer	Anuj Kumar / PHPGurukul
Assessment Target	http://localhost:8080/shopping/ (authorized local laboratory; localhost only)
Assessment Date	2026-11-01
Severity	Medium
CVSS	6.9 / CVSS:4.0 AV:N/AC:L/PR:N/UI:N/VC:H/VI:N/VA:N (impact realized after DB read)
CWE	CWE-916 / CWE-759 (Use of One-Way Hash without Salt)
OWASP	A02:2021 Cryptographic Failures
CVE Verification	No matching publicly assigned CVE was identified for this specific finding/version during the research performed. (No matching CVE)
Affected URL	Application-wide (login/signup/change/forgot-password; admin)
Affected Parameter	password
Affected Role	All
Authentication	n/a

Executive Summary

All passwords are stored as unsalted MD5 hashes, which are trivially reversible with rainbow tables; identical passwords produce identical hashes.

Technical Description

md5($_POST['password']) is used for every password write/compare. The database stores bare 32-hex digests. Four seeded accounts share f925916e2754e5e03f75dd58a5733251 = MD5('Test@123'); another is MD5('12345').

Root Cause Analysis

Fast, unsalted hashing unsuitable for passwords.

Preconditions

Hashes become exposed via any DB read (e.g. SHOP-003 UNION SQLi).

Proof of Concept — Step-by-Step Reproduction

1. From the DB (or via SHOP-003), obtain a hash, e.g. f925916e2754e5e03f75dd58a5733251.
2. A rainbow-table / dictionary lookup instantly yields 'Test@123'; 827ccb0eea8a706c4c34a16891f84e7b -> '12345'.
3. Identical hashes across accounts reveal shared passwords.

HTTP Request

```
(offline) echo -n 'Test@123' | md5sum  -> f925916e2754e5e03f75dd58a5733251 (matches stored admin &
 user hashes)
```

HTTP Response (evidence)

```
(offline) cracked plaintext recovered instantly
```

Proof of Concept & Visual Evidence

This finding is confirmed by source-code review and (where noted) database inspection; see the referenced primary evidence. No screenshot is required for a static/offline finding.

Actual Security Impact

Mass credential recovery once any hash is exposed; enables account/admin takeover.

Exploitation Complexity

Low (post-exposure).

Attack Scenario

Attacker reads hashes via SQLi (SHOP-003) and cracks them offline to log in as users/admin.

Remediation

password_hash()/password_verify() (bcrypt/argon2) with per-user salt; migrate on next login.

Secure Code Example

```
$hash=password_hash($pw,PASSWORD_DEFAULT); // verify: password_verify($pw,$hash)
```

Retesting Procedure

New/changed passwords must be stored as bcrypt/argon2 (prefix $2y$/$argon2), not 32-hex MD5.

References

- CWE-916/759; OWASP A02
- Evidence: database/database-schema.md (hashes)

Final Conclusion

Confirmed by source + DB inspection (Test@123/12345 cracked). Medium (High when chained).

Authorized local-laboratory assessment. Evidence chain sealed (evidence/shopping-portal/SEAL). Draft for human review — not auto-submitted. Secrets/PII in evidence are lab demo data; redact in externally-shared copies.